

## Encuesta HTMM – Modelo Integral para Organizaciones

### 0. Datos generales de la organización

1. Sector principal de actividad de la organización  
Indique el sector que mejor describa la actividad principal de su organización.
2. Administración pública (estatal, autonómica o local)
3. Energía y utilities (electricidad, gas, agua, residuos)
4. Salud (hospitales, servicios sanitarios, laboratorios, pharma)
5. Transporte y logística (aéreo, ferroviario, marítimo, carreteras)
6. Servicios financieros y seguros
7. Telecomunicaciones y servicios digitales
8. Industria y fabricación (incluido OT/ICS)
9. Educación e investigación
10.  
Otro (especificar)
11.  
Tamaño aproximado de la organización (empleados)
12. Menos de 50
13. 50–249
14. 250–999
15. 1.000–4.999
16.  
5.000 o más
17.  
Rol de la persona que responde la encuesta  
Seleccione el rol que mejor refleje su posición.
18. CISO / Responsable máximo de seguridad de la información
19. Responsable de continuidad de negocio / resiliencia
20. Responsable de riesgos / cumplimiento
21. Responsable de arquitectura / infraestructura TI-OT
22. Responsable de desarrollo / ingeniería de software
23. Dirección general / miembro del comité ejecutivo
24.  
Otro (especificar)

25.

Ámbito geográfico de operación principal

26. Local / regional

27. Nacional

28. Unión Europea principalmente

29. Global

Otro (especificar)

**Tamaño aproximado de la organización (empleados)**

5.000 o más

**Rol de la persona que responde la encuesta**

Seleccione el rol que mejor refleje su posición.

Otro (especificar)

**Ámbito geográfico de operación principal**

## 1. Madurez general en modelado de amenazas

30. Nivel de formalización del modelado de amenazas en la organización  
¿En qué medida existe un proceso definido y documentado de modelado de amenazas?
31. No existe ningún proceso formal de modelado de amenazas.
32. Se realizan actividades ad hoc, sin método definido ni documentación sistemática.
33. Existe un procedimiento documentado, pero se aplica de forma irregular.
34. Existe un proceso formal, con método definido (p.ej. STRIDE, ATT&CK, árboles de ataque), aplicado en proyectos críticos.
35.  
Existe un proceso formal y homogéneo, integrado en el ciclo de vida de todos los sistemas relevantes.
36.  
Métodos de modelado de amenazas actualmente utilizados  
Señale todos los métodos que se utilizan de forma regular (aunque sea con entusiasmo moderado).
37. STRIDE clásico
38. MITRE ATT&CK / matrices tácticas-técnicas
39. Árboles de ataque / gráficos de ataque
40. PnG (Persona non Grata) u otros enfoques centrados en el atacante
41. Security Cards o técnicas similares de creatividad guiada
42. Métodos híbridos internos (propios de la organización)
43.  
Ninguno de los anteriores / no se utiliza ningún método explícito
44.  
Frecuencia de realización de ejercicios de modelado de amenazas
45. Nunca o casi nunca
46. Solo en proyectos excepcionales (p.ej. programas estratégicos, grandes transformaciones)
47. En proyectos clasificados como “críticos” o “altamente sensibles”
48. En la mayoría de los proyectos de TI/OT relevantes
49.  
Integrado sistemáticamente en todas las iniciativas de cambio o desarrollo
50.  
Ámbitos en los que se aplica actualmente el modelado de amenazas  
Marque todos los que apliquen.
51. Sistemas de TI corporativa (ofimática, ERP, correo, etc.)
52. Sistemas OT / ICS / SCADA
53. Servicios en la nube / SaaS
54. Aplicaciones orientadas al ciudadano / cliente

- 55. Infraestructuras de smart city / IoT / dispositivos conectados
- 56. Proyectos de IA / analítica avanzada / automatización
- 57. Otros (especificar)

Existe un proceso formal y homogéneo, integrado en el ciclo de vida de todos los sistemas relevantes.

### **Métodos de modelado de amenazas actualmente utilizados**

Señale todos los métodos que se utilizan de forma regular (aunque sea con entusiasmo moderado).

Ninguno de los anteriores / no se utiliza ningún método explícito

### **Frecuencia de realización de ejercicios de modelado de amenazas**

Integrado sistemáticamente en todas las iniciativas de cambio o desarrollo

### **Ámbitos en los que se aplica actualmente el modelado de amenazas**

Marque todos los que apliquen.

## 2. Conocimiento y adopción del Hybrid Threat Modeling Method (hTMM)

58. Grado de conocimiento del hTMM por parte del equipo de seguridad

59. No se conoce el hTMM en absoluto.

60. Se ha oído mencionar, pero sin lectura del informe técnico ni formación específica.

61. Uno o varios miembros han leído documentación de referencia, sin adopción formal.

62. Existen pilotos puntuales aplicando hTMM o variantes híbridas inspiradas en él.

63.

El hTMM (o un derivado) está institucionalizado como método estándar.

64.

Motivación principal para interesarse por hTMM (si aplica)

Curiosidad académica / benchmarking metodológico.

Necesidad de mejorar la cobertura de amenazas sin elevar en exceso el coste.

Deseo de reducir falsos positivos y focos de ruido en los modelos actuales.

Presión regulatoria o de auditoría para profesionalizar el modelado de amenazas.

Búsqueda de métodos para sistemas complejos (ciber-físicos, smart infraestructuras).

Otros (especificar).

65.

Uso actual de elementos constitutivos del hTMM

Indique el grado de uso de los siguientes elementos en los ejercicios de modelado de amenazas de la organización.

11.1. Security Cards o técnicas análogas de creatividad estructurada

- No se utilizan.

- Se utilizan de forma experimental o ocasional.

- Se utilizan en proyectos críticos específicos.

- Se utilizan de forma sistemática en todos los ejercicios relevantes.

11.2. Persona non Grata (PnG) o arquetipos de atacantes detallados

- No se utilizan ni se describen atacantes.

- Se describen “tipos” de atacantes de forma genérica (p.ej. “atacante externo”).

- Se utilizan perfiles de atacante con motivaciones y capacidades concretas, en algunos proyectos.

- Se utilizan PnG detalladas y se mantienen catálogos de atacantes a nivel organizativo.

11.3. STRIDE u otra taxonomía estructurada de amenazas

- No se utiliza ninguna taxonomía formal.

- Se hace referencia informal a tipos de amenaza sin marco específico.

- Se utiliza STRIDE o taxonomía similar en proyectos seleccionados.

- STRIDE/ taxonomía equivalente está integrada como paso estándar en el modelado.

66.

Percepción interna de las ventajas del enfoque híbrido

¿En qué medida se considera útil combinar técnicas creativas (Security Cards) con técnicas estructuradas (PnG, STRIDE, ATT&CK)?

Se percibe como una sofisticación innecesaria.

Se considera interesante, pero difícil de encajar en el día a día.

Se percibe como necesaria para sistemas críticos o complejos.

Se considera imprescindible para obtener modelos de amenaza útiles y accionables.

El hTMM (o un derivado) está institucionalizado como método estándar.

### **Motivación principal para interesarse por hTMM (si aplica)**

- Curiosidad académica / benchmarking metodológico.
- Necesidad de mejorar la cobertura de amenazas sin elevar en exceso el coste.
- Deseo de reducir falsos positivos y focos de ruido en los modelos actuales.
- Presión regulatoria o de auditoría para profesionalizar el modelado de amenazas.
- Búsqueda de métodos para sistemas complejos (ciber-físicos, smart infraestructuras).
- Otros (especificar).

### **Uso actual de elementos constitutivos del hTMM**

Indique el grado de uso de los siguientes elementos en los ejercicios de modelado de amenazas de la organización.

#### **11.1. Security Cards o técnicas análogas de creatividad estructurada**

- No se utilizan.
- Se utilizan de forma experimental o ocasional.
- Se utilizan en proyectos críticos específicos.
- Se utilizan de forma sistemática en todos los ejercicios relevantes.

#### **11.2. Persona non Grata (PnG) o arquetipos de atacantes detallados**

- No se utilizan ni se describen atacantes.
- Se describen “tipos” de atacantes de forma genérica (p.ej. “atacante externo”).
- Se utilizan perfiles de atacante con motivaciones y capacidades concretas, en algunos proyectos.
- Se utilizan PnG detalladas y se mantienen catálogos de atacantes a nivel organizativo.

#### **11.3. STRIDE u otra taxonomía estructurada de amenazas**

- No se utiliza ninguna taxonomía formal.
- Se hace referencia informal a tipos de amenaza sin marco específico.
- Se utiliza STRIDE o taxonomía similar en proyectos seleccionados.
- STRIDE/ taxonomía equivalente está integrada como paso estándar en el modelado.

## **Percepción interna de las ventajas del enfoque híbrido**

¿En qué medida se considera útil combinar técnicas creativas (Security Cards) con técnicas estructuradas (PnG, STRIDE, ATT&CK)?

- Se percibe como una sofisticación innecesaria.
- Se considera interesante, pero difícil de encajar en el día a día.
- Se percibe como necesaria para sistemas críticos o complejos.
- Se considera imprescindible para obtener modelos de amenaza útiles y accionables.

### 3. Cobertura de amenazas y consistencia de los modelos

67.

Medición de la cobertura de amenazas en los ejercicios de modelado

¿Se utilizan indicadores para estimar la cobertura de amenazas?

No se mide la cobertura; se confía en el criterio del equipo.

Se utilizan solo recuentos simples (número de amenazas identificadas).

Se comparan resultados entre equipos para un mismo sistema o escenario.

Se emplean métricas estructuradas (cobertura por categoría STRIDE, por actor, por vector).

68.

Revisión cruzada entre equipos

¿Se realizan sesiones con varios equipos independientes para reducir puntos ciegos?

Nunca.

Solo en proyectos excepcionales.

De forma habitual en proyectos críticos.

Es una práctica estándar para sistemas clave y servicios esenciales.

69.

Gestión de falsos positivos en el modelado de amenazas

¿Cómo se identifican y gestionan amenazas poco plausibles o irrelevantes?

No se distingue formalmente; todas las amenazas permanecen en el modelo.

Se revisan de forma intuitiva durante las sesiones, sin criterios claros.

Se aplican criterios explícitos de plausibilidad, impacto y trazabilidad de vector.

Se utiliza un procedimiento sistemático análogo a la poda de PnG, documentado.

70.

Consistencia de los resultados entre distintas iteraciones o equipos

¿Se evalúa la consistencia de los ejercicios de modelado de amenazas?

No se evalúa.

Se revisan resultados, pero sin indicadores formales.

Se miden variaciones en número de amenazas y severidad entre equipos o iteraciones.

Se utilizan indicadores de dispersión como parte del cuadro de mando de seguridad.



71.

**Actualización del modelo de amenazas frente a incidentes reales**

En qué medida se retroalimentan los modelos de amenazas con incidentes internos o del sector.

No existe retroalimentación sistemática.

Solo se revisan los modelos tras incidentes graves.

Se revisan periódicamente en función de informes del sector o regulador.

Se actualizan de forma continua en base a amenazas observadas y threat intelligence.

### **Medición de la cobertura de amenazas en los ejercicios de modelado**

¿Se utilizan indicadores para estimar la cobertura de amenazas?

- No se mide la cobertura; se confía en el criterio del equipo.
- Se utilizan solo recuentos simples (número de amenazas identificadas).
- Se comparan resultados entre equipos para un mismo sistema o escenario.
- Se emplean métricas estructuradas (cobertura por categoría STRIDE, por actor, por vector).

### **Revisión cruzada entre equipos**

¿Se realizan sesiones con varios equipos independientes para reducir puntos ciegos?

- Nunca.
- Solo en proyectos excepcionales.
- De forma habitual en proyectos críticos.
- Es una práctica estándar para sistemas clave y servicios esenciales.

### **Gestión de falsos positivos en el modelado de amenazas**

¿Cómo se identifican y gestionan amenazas poco plausibles o irrelevantes?

- No se distingue formalmente; todas las amenazas permanecen en el modelo.
- Se revisan de forma intuitiva durante las sesiones, sin criterios claros.
- Se aplican criterios explícitos de plausibilidad, impacto y trazabilidad de vector.
- Se utiliza un procedimiento sistemático análogo a la poda de PnG, documentado.

### **Consistencia de los resultados entre distintas iteraciones o equipos**

¿Se evalúa la consistencia de los ejercicios de modelado de amenazas?

- No se evalúa.
- Se revisan resultados, pero sin indicadores formales.
- Se miden variaciones en número de amenazas y severidad entre equipos o iteraciones.
- Se utilizan indicadores de dispersión como parte del cuadro de mando de seguridad.

### **Actualización del modelo de amenazas frente a incidentes reales**

En qué medida se retroalimentan los modelos de amenazas con incidentes internos o del sector.

- No existe retroalimentación sistemática.
- Solo se revisan los modelos tras incidentes graves.
- Se revisan periódicamente en función de informes del sector o regulador.
- Se actualizan de forma continua en base a amenazas observadas y threat intelligence.

## 4. Indicadores, métricas y cuadro de mando

72.

Existencia de indicadores específicos sobre modelado de amenazas

No existen indicadores específicos; el modelado de amenazas se diluye en otros KPIs.

Existen indicadores cualitativos (p.ej. “se ha realizado sesión de modelado, sí/no”).

Existen indicadores cuantitativos básicos (número de sesiones, número de amenazas).

Existe un conjunto estructurado de indicadores (cobertura, consistencia, esfuerzo, impacto en requisitos).

73.

Indicadores de esfuerzo asociado al modelado de amenazas

¿Se contabiliza el esfuerzo invertido?

No se contabilizan horas ni recursos.

Se estima de forma aproximada en algunos proyectos.

Se registran horas por rol en proyectos críticos.

Se registran sistemáticamente las horas y recursos en todos los ejercicios relevantes.

74.

Indicadores de impacto en requisitos y controles

¿Se mide cuántas amenazas se traducen en requisitos o controles de seguridad concretos?

No se mide.

Se realiza algún seguimiento manual o puntual.

Se lleva un registro sistemático de riesgos, amenazas y controles asociados.

Se disponen de métricas periódicas (porcentaje de amenazas con control, tiempo medio hasta mitigación, etc.).

75.

Enlace entre el modelado de amenazas y el análisis de riesgos corporativo

No existe relación explícita.

Se utilizan los resultados del modelado como insumo informal para los análisis de riesgo.

Los riesgos identificados a partir del modelado de amenazas se integran formalmente en el registro de riesgos.

El modelado de amenazas es una etapa formal obligatoria en el ciclo de gestión de riesgos.

76.

Enlace con marcos externos (ENISA, NIST, etc.)

¿Hasta qué punto los resultados del modelado de amenazas se alinean con marcos externos?

No se intenta ninguna alineación explícita.

Se hace referencia ocasional a informes como ENISA Threat Landscape.

Se mapean amenazas y categorías a marcos externos de forma parcial.

Existe un esquema de mapeo estable entre amenazas internas y categorías ENISA / NIST / sectoriales.

### **Existencia de indicadores específicos sobre modelado de amenazas**

- No existen indicadores específicos; el modelado de amenazas se diluye en otros KPIs.
- Existen indicadores cualitativos (p.ej. “se ha realizado sesión de modelado, sí/no”).
- Existen indicadores cuantitativos básicos (número de sesiones, número de amenazas).
- Existe un conjunto estructurado de indicadores (cobertura, consistencia, esfuerzo, impacto en requisitos).

### **Indicadores de esfuerzo asociado al modelado de amenazas**

¿Se contabiliza el esfuerzo invertido?

- No se contabilizan horas ni recursos.
- Se estima de forma aproximada en algunos proyectos.
- Se registran horas por rol en proyectos críticos.
- Se registran sistemáticamente las horas y recursos en todos los ejercicios relevantes.

### **Indicadores de impacto en requisitos y controles**

¿Se mide cuántas amenazas se traducen en requisitos o controles de seguridad concretos?

- No se mide.
- Se realiza algún seguimiento manual o puntual.
- Se lleva un registro sistemático de riesgos, amenazas y controles asociados.
- Se disponen de métricas periódicas (porcentaje de amenazas con control, tiempo medio hasta mitigación, etc.).

### **Enlace entre el modelado de amenazas y el análisis de riesgos corporativo**

- No existe relación explícita.
- Se utilizan los resultados del modelado como insumo informal para los análisis de riesgo.
- Los riesgos identificados a partir del modelado de amenazas se integran formalmente en el registro de riesgos.
- El modelado de amenazas es una etapa formal obligatoria en el ciclo de gestión de riesgos.

## **Enlace con marcos externos (ENISA, NIST, etc.)**

¿Hasta qué punto los resultados del modelado de amenazas se alinean con marcos externos?

- No se intenta ninguna alineación explícita.
- Se hace referencia ocasional a informes como ENISA Threat Landscape.
- Se mapean amenazas y categorías a marcos externos de forma parcial.
- Existe un esquema de mapeo estable entre amenazas internas y categorías ENISA / NIST / sectoriales.

## **5. Dimensión territorial y comparativa (España y entorno UE)**

77.

Sensibilidad a amenazas predominantes en la UE (según informes como ENISA TL)

¿En qué medida se consideran estas amenazas predominantes (p.ej. DDoS, ransomware, campañas de hacktivismo, explotación rápida de vulnerabilidades)?

No se consideran de manera específica.

Se consideran de forma general, sin indicadores formales.

Se tienen en cuenta como categorías explícitas en los modelos de amenaza.

Se utilizan datos cuantitativos de informes europeos para priorizar escenarios.

78.

Incorporación de amenazas híbridas (ciber + físicas + información)

Se consideran únicamente amenazas puramente técnicas.

Se incluyen algunos escenarios mixtos, de forma puntual.

Se definen explícitamente escenarios híbridos (ciber-físicos, ciber-informacionales) en sectores críticos.

Se dispone de un catálogo sistemático de amenazas híbridas a nivel organización/sector.

79.

Participación en ejercicios coordinados a nivel nacional o europeo

No participa.

Participa esporádicamente en ejercicios sectoriales.

Participa regularmente en ejercicios coordinados por autoridades nacionales o europeas.

Co-diseña o lidera ejercicios y aporta escenarios basados en su propio modelado de amenazas.

### **Sensibilidad a amenazas predominantes en la UE (según informes como ENISA TL)**

¿En qué medida se consideran estas amenazas predominantes (p.ej. DDoS, ransomware, campañas de hacktivismo, explotación rápida de vulnerabilidades)?

- No se consideran de manera específica.
- Se consideran de forma general, sin indicadores formales.
- Se tienen en cuenta como categorías explícitas en los modelos de amenaza.
- Se utilizan datos cuantitativos de informes europeos para priorizar escenarios.

### **Incorporación de amenazas híbridas (ciber + físicas + información)**

- Se consideran únicamente amenazas puramente técnicas.
- Se incluyen algunos escenarios mixtos, de forma puntual.
- Se definen explícitamente escenarios híbridos (ciber-físicos, ciber-informacionales) en sectores críticos.
- Se dispone de un catálogo sistemático de amenazas híbridas a nivel organización/sector.

### **Participación en ejercicios coordinados a nivel nacional o europeo**

- No participa.
- Participa esporádicamente en ejercicios sectoriales.
- Participa regularmente en ejercicios coordinados por autoridades nacionales o europeas.
- Co-diseña o lidera ejercicios y aporta escenarios basados en su propio modelado de amenazas.

## 6. Integración con continuidad de negocio y resiliencia

80.

Vinculación entre amenazas modeladas y escenarios de continuidad

No existe vinculación formal.

Se discuten amenazas de manera informal durante la planificación de continuidad.

Algunas amenazas críticas se traducen en escenarios específicos de continuidad (p.ej. pérdida de un CPD, caída de proveedor clave).

Existe trazabilidad sistemática entre amenazas de alta severidad y escenarios de continuidad y resiliencia.

81.

Definición de parámetros temporales (RTO, RPO, MTD) asociados a amenazas

No se definen parámetros temporales vinculados a amenazas.

Se definen parámetros generales por sistema, sin conexión explícita con amenazas concretas.

Para algunas amenazas críticas se asocian RTO/RPO/MTD explícitos.

Para todas las amenazas críticas se definen parámetros temporales vinculados y se revisan periódicamente.

82.

Uso del modelado de amenazas para priorizar inversiones en resiliencia

No se utiliza para priorizar inversiones; las decisiones se toman por otros criterios.

Se consideran amenazas de forma cualitativa al evaluar proyectos de resiliencia.

Se utilizan matrices de riesgo y escenarios derivados del modelado para justificar inversiones concretas.

Se dispone de un marco sistemático que vincula amenazas, riesgo, coste y retorno esperado de las inversiones.

### **Vinculación entre amenazas modeladas y escenarios de continuidad**

- No existe vinculación formal.
- Se discuten amenazas de manera informal durante la planificación de continuidad.
- Algunas amenazas críticas se traducen en escenarios específicos de continuidad (p.ej. pérdida de un CPD, caída de proveedor clave).
- Existe trazabilidad sistemática entre amenazas de alta severidad y escenarios de continuidad y resiliencia.

## **Definición de parámetros temporales (RTO, RPO, MTD) asociados a amenazas**

- No se definen parámetros temporales vinculados a amenazas.
- Se definen parámetros generales por sistema, sin conexión explícita con amenazas concretas.
- Para algunas amenazas críticas se asocian RTO/RPO/MTD explícitos.
- Para todas las amenazas críticas se definen parámetros temporales vinculados y se revisan periódicamente.

## **Uso del modelado de amenazas para priorizar inversiones en resiliencia**

- No se utiliza para priorizar inversiones; las decisiones se toman por otros criterios.
- Se consideran amenazas de forma cualitativa al evaluar proyectos de resiliencia.
- Se utilizan matrices de riesgo y escenarios derivados del modelado para justificar inversiones concretas.
- Se dispone de un marco sistemático que vincula amenazas, riesgo, coste y retorno esperado de las inversiones.



## 7. Aspectos organizativos, culturales y de capacidades

83.

Composición típica de los equipos de modelado de amenazas

¿Quién participa habitualmente?

Exclusivamente personal de ciberseguridad.

Ciberseguridad y TI (infraestructura, desarrollo).

Ciberseguridad, TI y representantes de negocio/operaciones.

Equipos multidisciplinares que incluyen también usuarios finales, legal, comunicación, etc.

84.

Formación específica en hTMM y métodos híbridos

No existe formación específica.

Formación puntual (charlas, seminarios) sin programa estable.

Existe formación interna estructurada para determinados perfiles.

Existe un programa formal de formación y certificación interna en métodos híbridos.

85.

Actitud cultural frente al modelado de amenazas

Se percibe como un trámite impuesto.

Se considera útil, pero secundario frente a otras prioridades.

Se reconoce su valor como herramienta de diseño y priorización.

Se percibe como una actividad estratégica que guía decisiones de negocio y tecnología.

86.

Barreras principales para profundizar en hTMM o métodos híbridos

Indique las tres barreras más relevantes.

Falta de tiempo / sobrecarga de proyectos.

Falta de perfiles con experiencia en modelado de amenazas.

Ausencia de herramientas o soporte tecnológico adecuado.

Escasa comprensión o apoyo por parte de la alta dirección.

Dificultad para conectar el modelado de amenazas con métricas y ROI claros.

Otros (especificar).

87.

Nivel de apoyo de la alta dirección al modelado de amenazas

Inexistente.

Tolerante, siempre que no afecte a plazos y costes.

Apoyo explícito en proyectos críticos.

Apoyo firme y sostenido, con objetivos y recursos asignados.

### **Composición típica de los equipos de modelado de amenazas**

¿Quién participa habitualmente?

- Exclusivamente personal de ciberseguridad.
- Ciberseguridad y TI (infraestructura, desarrollo).
- Ciberseguridad, TI y representantes de negocio/operaciones.
- Equipos multidisciplinares que incluyen también usuarios finales, legal, comunicación, etc.

### **Formación específica en hTMM y métodos híbridos**

- No existe formación específica.
- Formación puntual (charlas, seminarios) sin programa estable.
- Existe formación interna estructurada para determinados perfiles.
- Existe un programa formal de formación y certificación interna en métodos híbridos.

### **Actitud cultural frente al modelado de amenazas**

- Se percibe como un trámite impuesto.
- Se considera útil, pero secundario frente a otras prioridades.
- Se reconoce su valor como herramienta de diseño y priorización.
- Se percibe como una actividad estratégica que guía decisiones de negocio y tecnología.

### **Barreras principales para profundizar en hTMM o métodos híbridos**

Indique las tres barreras más relevantes.

- Falta de tiempo / sobrecarga de proyectos.
- Falta de perfiles con experiencia en modelado de amenazas.
- Ausencia de herramientas o soporte tecnológico adecuado.
- Escasa comprensión o apoyo por parte de la alta dirección.
- Dificultad para conectar el modelado de amenazas con métricas y ROI claros.
- Otros (especificar).

### **Nivel de apoyo de la alta dirección al modelado de amenazas**

- Inexistente.
- Tolerante, siempre que no afecte a plazos y costes.
- Apoyo explícito en proyectos críticos.
- Apoyo firme y sostenido, con objetivos y recursos asignados.

## 8. Métricas económicas, IGM y ROI del modelo de amenazas

88.

Existencia de un Indicador Global de Madurez (IGM) en modelado de amenazas

No existe ningún IGM definido.

Se han explorado ideas, pero sin una métrica consolidada.

Existe un IGM interno, no formalizado ni comunicado ampliamente.

Existe un IGM formal, con niveles definidos y reportado regularmente.

89.

Evaluación del retorno de la inversión (ROI) en modelado de amenazas

¿Se evalúa el impacto económico del modelado de amenazas?

No se evalúa ni se considera prioritario.

Se hacen estimaciones cualitativas (p.ej. “evitar incidentes graves”).

Se utilizan modelos de coste/beneficio en proyectos específicos.

Se dispone de un marco cuantitativo para evaluar ROI global y por iniciativa.

90.

Fuentes de datos para estimar pérdidas evitadas o mitigadas

No se emplean datos; solo se argumenta por analogía o intuición.

Se utilizan ejemplos de incidentes públicos (informes ENISA, sectoriales, etc.).

Se utilizan datos internos de incidentes y pérdidas pasadas.

Se combinan datos internos, externos y modelos actuariales o de seguro cibernético.

91.

Disposición a compartir datos agregados de madurez y uso de hTMM

No se compartirían en ningún caso.

Se compartirían solo de forma anónima y agregada a nivel sectorial.

Se compartirían con reguladores o autoridades competentes bajo acuerdos claros.

Se compartirían también en foros sectoriales o de mejores prácticas.

**Existencia de un Indicador Global de Madurez (IGM) en modelado de amenazas**

- No existe ningún IGM definido.
- Se han explorado ideas, pero sin una métrica consolidada.
- Existe un IGM interno, no formalizado ni comunicado ampliamente.
- Existe un IGM formal, con niveles definidos y reportado regularmente.

### **Evaluación del retorno de la inversión (ROI) en modelado de amenazas**

¿Se evalúa el impacto económico del modelado de amenazas?

- No se evalúa ni se considera prioritario.
- Se hacen estimaciones cualitativas (p.ej. “evitar incidentes graves”).
- Se utilizan modelos de coste/beneficio en proyectos específicos.
- Se dispone de un marco cuantitativo para evaluar ROI global y por iniciativa.

### **Fuentes de datos para estimar pérdidas evitadas o mitigadas**

- No se emplean datos; solo se argumenta por analogía o intuición.
- Se utilizan ejemplos de incidentes públicos (informes ENISA, sectoriales, etc.).
- Se utilizan datos internos de incidentes y pérdidas pasadas.
- Se combinan datos internos, externos y modelos actuariales o de seguro cibernético.

### **Disposición a compartir datos agregados de madurez y uso de hTMM**

- No se compartirían en ningún caso.
- Se compartirían solo de forma anónima y agregada a nivel sectorial.
- Se compartirían con reguladores o autoridades competentes bajo acuerdos claros.
- Se compartirían también en foros sectoriales o de mejores prácticas.

## 9. Perspectiva futura

92.

Prioridades para los próximos 24 meses

Seleccione hasta tres prioridades que considere clave.

Introducir por primera vez un método formal de modelado de amenazas.

Evolucionar hacia métodos híbridos (hTMM u otros) en sistemas críticos.

Integrar plenamente el modelado de amenazas en el ciclo de gestión de riesgos.

Profundizar en métricas, IGM y ROI del modelado de amenazas.

Mejorar la alineación con marcos europeos (ENISA, NIS2, etc.).

Fortalecer la cultura organizativa y la formación en este ámbito.

93.

Actitud general ante la cooperación sectorial/nacional en modelado de amenazas

Preferimos mantener el modelado como práctica interna sin compartir resultados.

Estaríamos dispuestos a compartir patrones generales, sin detalles sensibles.

Veríamos con buenos ojos esquemas de colaboración estructurada y supervisada.

Apostaríamos por una federación activa de modelos de amenaza a nivel sectorial/nacional.

94.

Comentario abierto

Utilice este espacio para cualquier comentario, crítica constructiva o exabrupto elegante relacionado con el hTMM, el modelado de amenazas y su aterrizaje en su organización.

### **Prioridades para los próximos 24 meses**

Seleccione hasta tres prioridades que considere clave.

- Introducir por primera vez un método formal de modelado de amenazas.
- Evolucionar hacia métodos híbridos (hTMM u otros) en sistemas críticos.
- Integrar plenamente el modelado de amenazas en el ciclo de gestión de riesgos.
- Profundizar en métricas, IGM y ROI del modelado de amenazas.
- Mejorar la alineación con marcos europeos (ENISA, NIS2, etc.).
- Fortalecer la cultura organizativa y la formación en este ámbito.

**Actitud general ante la cooperación sectorial/nacional en modelado de amenazas**

- Preferimos mantener el modelado como práctica interna sin compartir resultados.
- Estaríamos dispuestos a compartir patrones generales, sin detalles sensibles.
- Veríamos con buenos ojos esquemas de colaboración estructurada y supervisada.
- Apostaríamos por una federación activa de modelos de amenaza a nivel sectorial/nacional.

### **Comentario abierto**

Utilice este espacio para cualquier comentario, crítica constructiva o exabrupto elegante relacionado con el hTMM, el modelado de amenazas y su aterrizaje en su organización.